明镜 · 一期地基自检单

全部打勾 = 一期地基完成。这一页打印出来，贴在团队墙上。

> 每条只写两样：**做什么 + 怎么算过**。详细要求见 3_技术方案.md（第 10 节与附录 A/B）。

第 1 周 · 地基四件（没做完不许开业务接口）

- ☐ 1 账号 / 身份 / 任职 三张表 + 统一登录网关
  过：造一个"既是运营又在播"的人，他能选进哪个门，两个身份互不干扰

- ☐ 2 多租户中间件：自动带上"我的公司"
  过：故意不写公司条件去查 → 返回 0 条

- ☐ 3 数据库行级安全（第二道门锁）
  过：第一道被绕过时，数据库仍然拦住

- ☐ 4 ★ CI 测试：越权与跨租户（进 CI，不是本地跑一次）
  过：CI 里能看到它跑过，且是绿的

- ☐ 5 权限三层：功能（角色）+ 范围（本人/本组/本部门/全公司）+ 字段标签
  过：改一个字段的可见岗位，不用改代码、不用发版

- ☐ 6 AI 的权限 = 提问者的权限
  过：用低权限账号问 AI"公司里谁工资最高" → 它答不出来

- ☐ 7 ai_usage 计量表（按月分区）+ 三个标记的强制规范
  过：表里不存在任何一条缺"公司 / 人 / 功能"的记录

- ☐ 8 成本四个粒度可查（全平台 / 每家公司 / 每个人 / 每一类功能）
  过：四张视图都能出数，且能对得上明细

第 2 周 · 门和入驻

- ☐ 9 登录 / 验证码 / 身份切换（/pub）
  过：一个人两个身份，能切，切完数据跟着变

- ☐ 10 入驻申请提交（5 个输入框）
  过：一个没账号的公会，5 分钟能填完并提交

- ☐ 11 审核（通过 / 驳回，理由选模板不手写）
  过：后台点两个按钮完成审核，不用打字

- ☐ 12 ★ 一键开号 + 装入行业默认岗位模板
  过：新公会开号后看到的是"装好的系统"，不是空白

- ☐ 13 激活漏斗的数据来源（申请 → 审核 → 开户 → 激活）
  过：能算出每一步的转化，且"激活"按定义口径

☐ 14　公会端组织与权限 6 个接口（部门 / 员工 / 岗位 / 字段策略）
过：客户自己在界面上就能配岗位和字段，不找我们

持续 • 每次提交前必过（进 CI，红了不许合）

☐ 15　用主播身份调【所有】公会端接口 → 全部被拒
过：断言通过；且每次越权尝试都被记进日志

☐ 16　扫主播端接口返回的 JSON → 不含任何禁用字段
过：按附录 B.5.1 的清单逐名断言

☐ 17　入参里故意带上别家公司的 tenant_id → 被忽略
过：不报错、也不返回别家数据（以登录态为准）

没打勾的项，为什么

第 ___ 项：_____
第 ___ 项：_____
第 ___ 项：_____

写"为什么"比打勾重要。 打勾只说明做完了；**写清"哪一条没过、卡在哪"，才知道该找谁、该改哪一层。**